SAFETY 4.0

Arminoks Süt Otomatı

LAB 1–5 · Machine Starter Pack

Batuhan Yaşar Özkan
230541050 · Atama no: 35 · SAMİB
26 Ekim 2026

Açık kaynaklı ürün bilgisi, açık varsayımlar ve izlenebilir gereksinimlerle hazırlanmış eğitim analizi.

İçerik: Makine profili · Emniyet mimarisi · Zone/conduit · Risk Register · Güvenli uzaktan erişim · Yama kararı · SWOT · Teslim kontrolü

Belge teslimi hazırlanmıştır. Gerçek cihazda uygulama ve emniyet doğrulaması yapılmamıştır.

00 | Makine profili ve ortak kabuller

Batuhan Yaşar Özkan · 230541050 · Arminoks Süt Otomatı (SAMİB) · 26.10.2026

Amaç, yöntem ve nihai teslim

Çalışma, üreticiye başvurmadan açık kaynak üzerinden yapılan kör analizdir. İstenen sonuç, LAB 1–5 sorularının aynı makine modeliyle yanıtlandığı, kaynak/varsayım ayrımı yapılmış bir Machine Starter Pack'tir. Makineye erişim, keşif taraması, parola denemesi veya fiziksel müdahale yapılmaz. Gerçek kurulum hakkında emniyet veya zafiyet hükmü verilmez.

Bilgi etiketleri bütün bölümlerde aynıdır: **D** doğrulanmış ürün ailesi özelliği; **V** analiz varsayımı; **H** hedef öneri. D etiketi, özelliğin belirli bir seri numarasında kurulu veya güvenilir olduğu anlamına gelmez.

Doğrulanan ürün ailesi bilgileri

Aşağıdaki kısa teknik özet K01'in süt otomatı bölümünden (PDF sayfa 4–6) alınmıştır. Broşürün sayfa 3'ündeki ayrı süt dolum makinesi ve soğutma tankı aynı makine kabul edilmemiştir.

Kod	Özellik	Dayanak
D01	AISI 304 kabin, 220 V besleme	K01, s.5
D02	Soğutma aralığı 0–4 °C; sıcaklığı panelden izleme	K01, s.5
D03	50/100/200/400 L seçenekleri; tanklı tipte 200/400 L	K01, s.5–6
D04	Programlanabilir karıştırma; kendinden emişli dolum pompası	K01, s.5
D05	Dokunmatik panel, satış geçmişi için USB	K01, s.5
D06	SMS bilgi paylaşımı modülü opsiyonu	K01, s.5
D07	Dolum sonrasında dolum ünitesinin otomatik yıkanması	K01, s.5
D08	Ödeme/barkod seçenekleri	K01, s.4–6

Bu bilgiler ürün ailesini tanımlar. Analizde kapasiteye bağlı hesap yapılmadığından keyfî kapasite seçilmez. Broşürdeki 0–4 °C ürün özelliğidir; süre-sıcaklık açısından gıda kabul ölçütü veya mevzuat sınırı olarak kullanılmaz.

İş akışı ve sistem sınırı

Modelde ürün tankına süt alınır; soğutulur ve karıştırılır; satış talebi ve izin koşulları sağlanınca pompalanır; dolum sonrası temizleme sırası yürütülür. Bakımda satış durdurulur ve gerekli enerjiler izole edilir. Bu akışın kontrol ayrıntıları V01–V09 kapsamındadır.

Sınır: otomatın paneli, varsayımsal kontrolörü, karıştırıcı/pompa/soğutma/temizlik çıkışları, sensörler, bakım aracı, USB ve opsiyonel SMS. Tedarikçi, işletme ağı ve internet dış sınırdır. Robot, SCADA, MES, yapay zekâ, pastörizasyon, tam tesis CIP hattı ve doğrulanmamış bulut hizmeti eklenmemiştir. Çiğ süt otomatı, pastörizatör sayılmaz.

Ortak varsayım defteri

Kod	Eğitim kabulü	Hangi sonuç buna bağlı?	Yanlışsa ne değişir?
V01	Panelin bağlı olduğu programlanabilir bir kontrolör vardır; marka ve sürüm bilinmez	Bütün kontrol modeli	Ayrık kontrolör yoksa panel/entegre kontrolör olarak birleştirilir
V02	Karıştırıcıya bakım/temizlik sırasında erişim mümkündür	SF-01, SF-03; R-01 ve R-04	Erişim fiziksel olarak imkânsızsa bu yaralanma zinciri yeniden kurulur
V03	Satış ve otomatik yıkama aynı dolum bölümünü kullanır; örnek tehlike analizinde temizlik maddesi/sıcak akış ihtimali ayrıca varsayılır	SF-04; R-03	Yalnız soğuk su varsa kimyasal/yanık sonucu çıkarılır
V04	Sıcaklık sensörü ve satış izni yazılıma bağlıdır	SF-02; R-02	Bağımsız izleme varsa zincir o kontrol üzerinden tekrar incelenir
V05	LAB 2–4 başlangıç senaryosunda servis için bir uzak bakım ağ geçidi ve bakım bilgisayarı bulunur; servis yolu sürekli açıktır	C01–C03, R-01	Uzaktan erişim yoksa R-01 temel kurulumdan çıkar; yerel riskler kalır
V06	V05 yolunda değiştirilmemiş varsayılan kimlik doğrulama ve kısıtsız kontrolör yazma yetkisi kabul edilir	R-01 L3/E3	Gerçek erişim kontrolleriyle L/E yeniden puanlanır
V07	Yerel servis hesabı paylaşılır; USB için kontrollü aktarım politikası yoktur	R-02 ve R-03	Kişisel hesap ve kontrollü aktarım varsa L yeniden değerlendirilir
V08	Başlangıçta koruyucu kapak/yeniden başlama denetimi normal kontrol yazılımına bağımlıdır; güncelleme kanalı yeterince doğrulanmaz	R-01/R-04	Bağımsız donanım ve değişiklik kontrolleri varsa zincir kesilebilir
V09	Yıkama başarısı ve durulama onayı için kontrol sinyalleri modellenir; gerçek sensör/valf topolojisi bilinmez	SF-04, test D04	Kanıtsız sinyal başarı kabul edilmez; gerçek tasarımla yenilenir
V10	LAB5'te Component X v2.4, CVSS 9.8 ve yama varlığı föyün temsili girdisidir	VD-01	Gerçek bileşen/CVE bulunduğunda ayrı kayıt açılır

Önemli ayrım: USB portunun bulunması D05; o porttan program çalıştırılabilmesi V07/V08'dir. SMS seçeneği D06; internet, 4G router, uzaktan komut alma veya servis protokolü varlığı değildir. Ayrı Safety PLC veya emniyet rölesi **kurulu varsayılmaz**; hedefte gereken işlevsel bağımsızlık tanımlanır.

Güvenilirlik ve sınırlar

PLr/SIL, eldeki broşürden atanamaz. Duruş süresi, kapak erişim süresi, kullanım sıklığı, kaçınma olanağı, devre kategorisi ve bileşen verileri bilinmez. L×S×E dersin sadeleştirilmiş siber-fiziksel önceliklendirmesidir; ISO 13849/IEC 62061 hesabı değildir. Gıda güvenliği işlevleri de doğrudan bir PL/SIL belgesi sayılmaz.

Kaynak kaydı

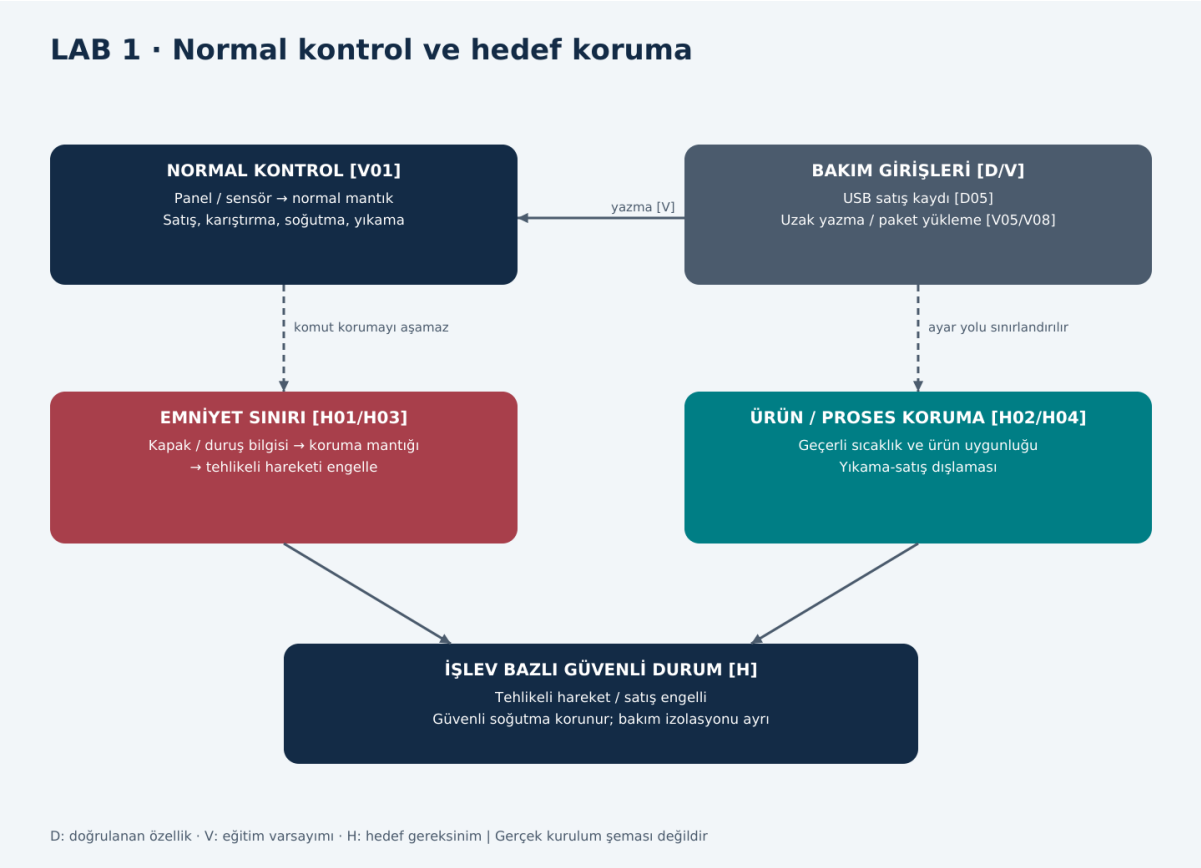
ID	Kaynak	Kullanım / sınır
T01	Öğretmenin 2.1. lab_foyleri_genel.pdf, 8 sayfa	LAB1–5 ana soru ve çıktı yapısı; s.2–6
T02	Öğretmenin 2.2 lab_foyleri_paketpro.pdf, 8 sayfa	Makineye uyarlama örneği; PaketPro özellikleri Arminoks'a aktarılmaz
T03	Öğretmenin LAB3.pdf, 48 sayfa	s.23–33 ölçek/Register; s.43 görev; s.46 tartışma
K01	Arminoks süt otomatı broşürü	Süt otomatı ürün ailesi özellikleri, özellikle s.4–6
K02	NIST SP 800-82 Rev.3	OT güvenliği, segmentasyon, uzak erişim ve değişiklik yönetimi için genel rehber

Erişim tarihi: 26.10.2026. İnternet kaynakları resmî üretici ve NIST kaynaklarıdır. Öğretmen belgeleri özel olarak paylaşıldığı için açık repoda yeniden dağıtılmaz. ISO/IEC standartlarının tam metinlerine dayalı bir uygunluk denetimi yapıldığı iddia edilmez. Mevzuat kapsam/tarih analizi LAB1–5 teslimine eklenmemiştir.

LAB 1 | Safety Architecture

Çıktı: Safety Function Map · **EP 03** · T01/T02 s.2

Normal işletme kontrolü satışın gerçekleşmesini sağlar. Emniyet yolu ise kontrol yazılımı arızalansa veya yetkisiz değişse bile tanımlanmış tehlikeyi engellemelidir. Aşağıdaki şema **H hedefidir**, kurulu Arminoks devresi değildir. Ortak kabuller: V01–V04, V08–V09.



Normal kontrol ve hedef koruma yolları

Föy soruları ve yanıtları

L1-Q1 | Bu makinede tehlike nedir? İnsan neyden zarar görür?

Bakım sırasında erişilebilir kabul edilen karıştırıcının beklenmedik çalışması el/kolun yakalanmasına yol açabilir (V02). Dolum ve temizlik yollarının yanlış sırada açılması temizlik maddesi veya sıcak akışla temasa neden olabilir (V03). Sıcaklık verisi bozularak uygunluğu belirsiz ürünün satılması tüketiciye biyolojik zarar yolu oluşturabilir (V04); tek bir sıcaklık sapması otomatik olarak hastalık kanıtı sayılmaz. Islak ortamda elektrik tehlikesi ayrıca tasarım incelemesi gerektirir; siberden elektrik çarpmasına kanıtsız bir zincir kurulmamıştır.

L1-Q2 | Safety function (emniyet fonksiyonu) hangisidir?

ID	İşlev ve tetikleyici	Güvenli tepki	Niteliği
SF-01	Karıştırıcı erişim kapağı açılması / koruma hatası	Hareketi engelle; tam durmadan tehlikeye erişimi önle	Makine emniyeti hedefi, V02/V08
SF-02	Sıcaklık ölçümü geçersiz veya ürün uygunluğu belirsiz	Satışı engelle, kayıt/uyarı oluştur; güvenli soğutmayı koru	Ürün/gıda güvenliği hedefi, V04
SF-03	Bakım sonrası reset veya enerji geri gelmesi	Kendiliğinden başlatma yok; ayrı yerel başlatma gerekir	Makine emniyeti hedefi, V08
SF-04	Yıkama aktif, durulama/temizlik durumu belirsiz	Ürün dolumu kapalı; satış ve yıkama birbirini dışlar	Proses/gıda ve koşullu termal-kimyasal koruma, V03/V09

SF kodları analizde izlenebilirlik sağlar; dört işlevin de sertifikalı functional safety işlevi olduğu iddia edilmez. Acil durdurma gereksinimi gerçek tehlike değerlendirmesinde ayrıca belirlenmelidir; broşürde E-stop/Safety PLC doğrulanmamıştır.

L1-Q3 | Safety-related control system nerede? Şemada işaretleyin.

Şemada koyu kırmızı koruma bölümü, SF-01/SF-03 için önerilen emniyetle ilgili kontrol sınırıdır: güvenilir kapak/duruş bilgisi → emniyet mantığı → tehlikeli hareketi kesen ve geri bildirimle izlenen çıkış. SF-02/SF-04 ayrı ürün/proses koruma bloğudur. Normal panel ekranı veya tek sıcaklık göstergesi kendi başına safety-related control system sayılmaz. Donanım tipi ve gereken güvenilirlik tasarım doğrulamasına bağlıdır.

L1-Q4 | Normal PLC ile Safety PLC farkı nedir?

Normal PLC üretim sırası ve miktar gibi işletme kararlarını yürütür. Safety PLC ise uygun tasarım ve doğrulamayla emniyet işlevlerini, arızaların algılanmasını ve güvenli tepkiyi yürütmek için geliştirilmiş kontrolördür. Ayrı isim veya farklı IP adresi bağımsızlığı kanıtlamaz; sensör, mantık, çıkış, programlama yolu ve ortak nedenli arızalar birlikte incelenir. Bu makinenin kontrolör türü bilinmemektedir.

L1-Q5 | PLr / SIL neden var? Bu fonksiyon için neden önemli?

Tehlikenin gerektirdiği risk azaltımıyla emniyet işlevinin güvenilirliğini ilişkilendirmek için kullanılır. Örneğin SF-01'in arıza halinde erişilebilir hareketi güvenle engelleyebilmesi gerekir. Ancak S/F/P girdileri, tepki süreleri ve devre bilgileri olmadığından PLr veya SIL numarası verilmez. Risk Register'daki S3, doğrudan PL e veya SIL3 anlamına gelmez.

L1-Q6 | Safe state (güvenli durum) nedir?

Bakım erişiminde hareket durur ve yeniden başlama engellenir. Uygunluğu belirsiz sütte satış kilitlenir; güvenli soğutma mümkünse sürer ve ürün ayrılır. Temizlikte satış kapalı kalır ve tehlikeli akış kullanıcının erişebildiği bölüme verilmez. Ağ/panel kaybı satış iznini kendiliğinden oluşturamaz. Bakım için elektrik ve depolanmış enerjinin güvenli izolasyonu gerekir; işletme duruşu tam izolasyon değildir.

L1-Q7 | Safety function hangi dijital bağımlılıklara sahip?

Kapak/reset mantığı, parametreler ve firmware (SF-01/03); sıcaklık sensörü ölçeklemesi, veri geçerliliği ve satış izni (SF-02); yıkama-satış sırası ve tamamlanma kayıtları (SF-04). Bakım aracı, yazılım yüklemesi ve hesap yetkileri bu mantığı etkileyebilen yollardır. USB'den bunlara erişim teknik olarak doğrulanmamış, V07/V08 kapsamında modellenmiştir.

L1-Q8 | Siber müdahale hangi noktadan bu fonksiyonu bozar?

V05/V06 başlangıcında uzak servis → bakım aracı → normal kontrolör yazma yolu, V08'de normal yazılıma bağlı kapak mantığını değiştirebilir. Yerel servis hesabı sıcaklık ayarını (V04/V07); doğrulanmamış aktarım/güncelleme yolu temizlik sırasını (V03/V07/V08) etkileyebilir. Bunlar LAB2 envanterindeki G01–G06 girişlerine ve LAB3 R-01–R-04 kayıtlarına bağlanır.

Ek sorular ve yanıtları

L1-E1 | Her şeyi kapatmak neden her zaman güvenli değildir?

Hareketi durdurmakla soğutmayı durdurmak farklıdır. Ağ sorunu nedeniyle dolum kapatılırken soğutmanın güvenli devamı ürünün daha fazla bozulmasını önleyebilir. Tam enerji kesilmesi bakımda gerekli olabilir; bu durumda ürün korunması ayrı prosedürle ele alınır.

L1-E2 | Panel normal sıcaklık gösteriyorsa satış yapılabilir mi?

Tek ekran bilgisi yeterli değildir. Ölçüm geçerliliği, geçmiş sapmalar, temizleme durumu ve yetkili ürün serbest bırakma kararı gerekir. Ekranın ve kararın aynı veriden beslenmesi ortak hata kaynağıdır. Kesin sıcaklık-süre eşikleri bu çalışmada uydurulmaz.

L1-E3 | Reset neden başlatma olmamalı?

Reset yalnız hatanın giderildiğini kabul eder; kişiyi tehlikeli bölgede bırakarak hareket başlatamaz. H03 gereği enerji dönüşünde ve bakım sonrası ayrı yerel başlatma koşulu aranır.

L1-E4 | Emniyet bağımsızlığını nasıl sınarız?

Yetkili bir laboratuvar düzeninde normal kontrolöre hareket komutu verilirken kapak açık durumu oluşturulur; hareketin engellenmesi, hata kilidi ve beklenmeyen yeniden başlama gözlenir. Uzaktan/USB yolla koruma parametresi değiştirilememesi de incelenir. Bu repo test planı verir; gerçek makinede test yapıldığı söylenmez.

LAB 2 | IEC 62443 Zone / Conduit

Çıktı: Envanter + Zone/Conduit Diagram · **EP 01 / EP 05** · T01/T02 s.3

T01'in şişeleme hattı varlıkları süt otomatına işlevsel olarak uyarlanmıştır. Robot ve SCADA eklenmez. T02'nin port 80, kartona yazılı Wi-Fi ve iki USB ifadesi gerçek Arminoks bulgusu sayılmaz. Aşağıdaki başlangıç uzak erişim senaryosu V05/V06'dır; gerçek cihazın topolojisi bilinmemektedir.

Envanter: altı kategori

ID	Kategori / varlık	Bilgi türü ve sınır
A01	Donanım: dokunmatik panel	D05; model bilinmez
A02	Donanım: programlanabilir kontrolör	V01; ayrı PLC olduğu doğrulanmaz
A03	Donanım: karıştırıcı ve dolum pompası	D04; sürücü/valf topolojisi V01
A04	Donanım: soğutma ve sıcaklık ölçümü	D02; sensör tipi, hata tanısı V04
A05	Donanım: yıkama ve dolum akışı	D07; kimyasal/sıcak akış ve valf düzeni V03/V09
A06	Donanım: USB girişi	D05; port sayısı/yazma yeteneği bilinmez
A07	Donanım: bakım bilgisayarı	V05/V08
A08	Donanım: uzak bakım ağ geçidi	V05; SMS modülüyle aynı cihaz değildir
A09	Donanım: SMS bildirim modülü	D06 opsiyon; kurulu olduğu varsayılmaz
A10	Donanım: kapak ve hareket koruma zinciri	H01/H03; gerçek donanım bilinmez
W01	Yazılım: panel uygulaması	V01; sürüm bilinmez
W02	Yazılım: kontrol mantığı / firmware	V01/V08; üretici ve bileşenler bilinmez

ID	Kategori / varlık	Bilgi türü ve sınır
W03	Yazılım: bakım/güncelleme aracı	V05/V08; ürün adı bilinmez
W04	Yazılım: koruma konfigürasyonu	H01–H04; kurulu Safety PLC varsayılmaz
U01	Hesap: yerel operatör	V01/V07
U02	Hesap: paylaşılan yerel servis	V07; gerçek parola bilinmez
U03	Hesap: uzak servis	V05/V06; eğitimde varsayılan kimlik bilgisi
K01-A	Anahtar: servis erişim kimlik bilgisi	V06; gerçek anahtar/parola toplanmadı
K02-A	Anahtar: yazılım doğrulama güven kökü	H05; üreticide kurulu olduğu iddia edilmez
B01	Dış bağlantı: uzak servis yolu	V05

ID	Kategori / varlık	Bilgi türü ve sınır
B02	Dış bağlantı: çıkarılabilir USB aktarımı	D05; program yükleme V07/V08
B03	Dış bağlantı: opsiyonel SMS bildirimi	D06; komut kanalı kabul edilmez
F01	Veri: sıcaklık, miktar ve alarm	D02/D05; veri yolu V01/V04
F02	Veri: satış geçmişi	D05; bütünlük kontrolü H05

ID	Kategori / varlık	Bilgi türü ve sınır
F03	Veri: konfigürasyon, yazılım paketi ve yedek	V01/V08
F04	Veri: yıkama/durulama izni	V09; ölçüm yöntemi bilinmez

Senaryolarda kullanılan altı giriş kapısı

Kapı	Envanter bağlantısı	Senaryo kullanımı
G01	A08/B01/U03 uzak servis	R-01; sürekli açık varsayımı
G02	A01/U02 yerel servis ekranı	R-02; fiziksel erişim
G03	A06/B02 USB veri aktarımı	R-03; yükleme etkisi varsayımsal
G04	A07/W03/F03 servis paketi	R-04; tedarik zinciri
G05	A02/W02 bakım-programlama arayüzü	R-01/R-04 zincirinin iç adımı
G06	Hedef koruma konfigürasyonu W04	Yerel yetkili bakım dışında yazma olmamalı

En az beş kapı koşulu sağlanır (T03 s.43). B03'ün giriş komutu alması kanıtlanmadığından saldırı kapısı olarak kullanılmaz. Bir bağlantının envanterde bulunması istismar edilebilirliğini kanıtlamaz.

Görev A

L2-A1 | Hangi varlıklar aynı bölgede? Bölgeleri adlandırıp gruplandırın.

Zone	Varlıklar	Hedef sınır
Z0 Dış servis	Tedarikçi, internet, dış USB kaynağı	Güvenilmeyen dış sınır
Z1 İşletme/ödeme	İşletme ağı; varsa D08 ödeme sistemi	Kontrole doğrudan yazma yok
Z2 Bakım geçidi	A08 ve hedef jump server/VPN	Süreli, kayıtlı giriş
Z3 Bakım istasyonu	A07, W03, F03	Onaylı aktarım/değişiklik
Z4 Normal kontrol	A01–A06, W01/W02, U01/U02, F01/F02/F04	İşletme ve proses kontrolü
Z5 Koruma	A10/W04 ve H01–H04 işlevleri	Normal kontrolden bağımsız koruma sınırı

Bu mantıksal bölümlendirmedir; her zone ayrı fiziksel sunucu veya ağ kartı gerektirmez. Ödeme varsa dolum talebi ile koruma izni ayrılır; ödeme onayı tek başına dolum izni olamaz.

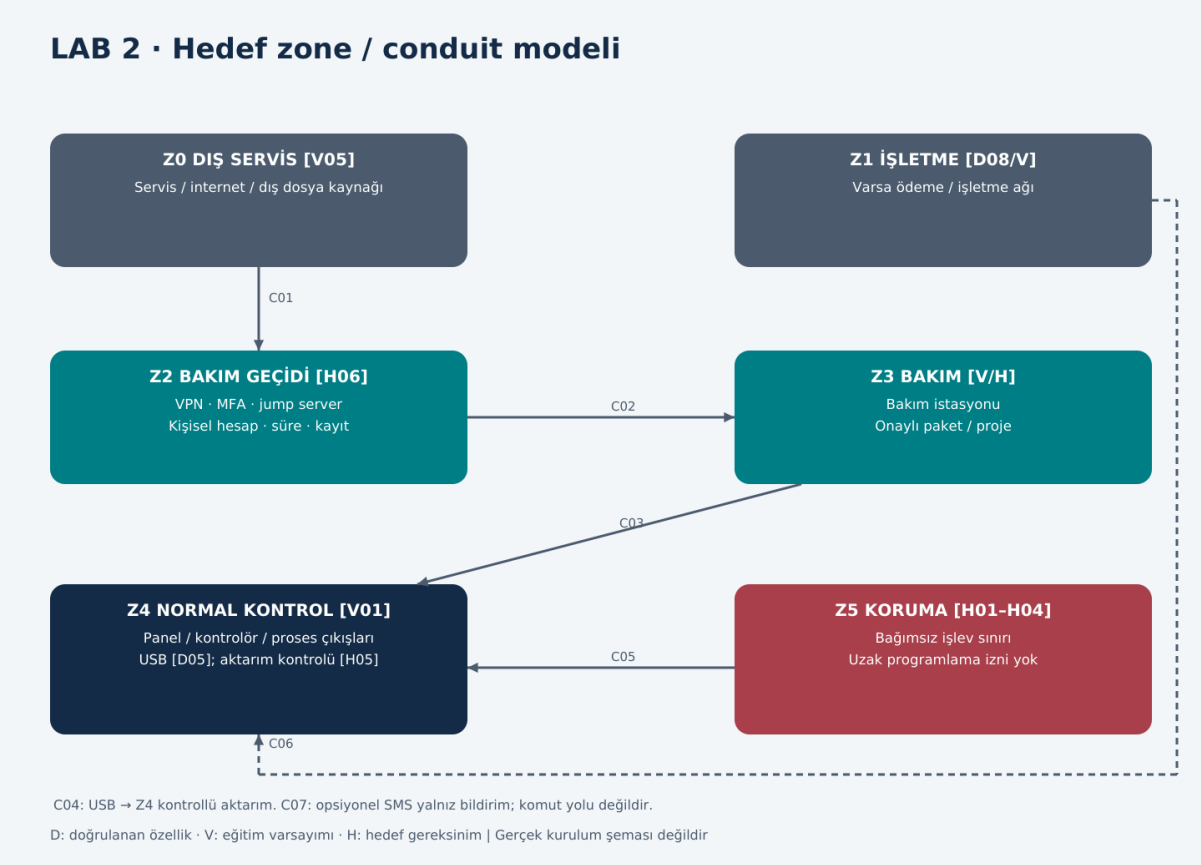
L2-A2 | Safety PLC'yi hangi bölgeye koydunuz, neden?

Gerçek makinede Safety PLC doğrulanmadı. İşlevsel hedefte emniyet mantığı Z5'tedir. Gerekli güvenilirlik, teknoloji ve devre seçimi yetkili tasarımla belirlenir. Z4 kontrolörünün ele geçirilmesi, Z5'in koruma kararını veya programını değiştirme hakkı vermemelidir. Aynı bakım aracı iki bölgeye sınırsız yazabiliyorsa ayrı zone etiketi tek başına yeterli değildir.

L2-A3 | Conduit'ler nerede? Her geçişte ne kontrol edilecek?

ID	Geçiş	Hedef kontrol / doğrulama
C01	Z0 → Z2 uzak giriş	VPN, MFA, kişisel hesap; yalnız izinli bakım penceresi
C02	Z2 → Z3 oturum	Jump server; görev bazlı yetki; bağlantı ve işlem kaydı
C03	Z3 → Z4 bakım yazması	Belgelenmiş gerekli protokole izin; varsayılan salt okunur; yazma yerel onaylı
C04	USB → Z4	Onaylı ortam ve dosya türü; tarama; uygulama kontrolü; kaydı belirsiz dosyayı reddet
C05	Z5 → tehlikeli çıkış / Z4 durum bilgisi	Koruma öncelikli; Z4 komutu korumayı geçersiz kılamaz; fiziksel test gerekir
C06	Z1 → Z4 işletme/ödeme talebi	Yalnız gerekli işlem; ödeme ağından kontrolör programlama yok
C07	Z4 → dış SMS altyapısı, opsiyonel	Yalnız bildirim kabulü; gelen komut destekleniyorsa yeni risk analizi

C03'te IP/port sayıları cihaz kılavuzu olmadan uydurulmaz. İzin listesi kural tanımıdır, kurulmuş firewall kanıtı değildir. C05 mantıksal/fiziksel işlev sınırıdır; gerçek ağ bağlantısı bulunduğu iddiası değildir.



Hedef zone ve conduit diyagramı

L2-P1 | PaketPro varyantı: Açık uzak bakım modülü hangi bölgeye düşüyor; orada kalabilir mi?

V05/V06 başlangıcındaki modül dış dünya ile kontrol arasında denetimsiz köprüdür. Hedefte Z2 kontrollü geçidine alınır; Z4/Z5'e doğrudan erişim yetkisi bulunmaz. İnternet erişimi bütünüyle yoksa bu modül temel sisteme eklenmez; LAB4 tasarımı gelecekteki entegrasyon gereksinimi olarak okunur.

Görev B: altı uzak erişim kararı

ID / karar	Seçim	Gerekçe
L2-B1 Aracı	Jump server	Tek kontrollü ve kayıtlı giriş noktası
L2-B2 Tünel	VPN	Bakım trafiğinin korunması; tek başına yetkilendirme değildir
L2-B3 Kimlik	MFA	Parolanın tek başına girişe yetmemesi
L2-B4 Hesap	Kişisel	Sorumluluk, iptal ve izlenebilirlik
L2-B5 Kayıt	Tam oturum + değişiklik kaydı	Kimin neyi değiştirdiğini ilişkilendirme
L2-B6 Zamanlama	Varsayılan kapalı	Yerel onaylı iş emri ve otomatik süre sonu

Ek sorular ve yanıtları

L2-E1 | SMS modülü internet saldırı yolu mudur?

Bildirim özelliği bunu kanıtlamaz. SIM/operatör bağlantısı, gelen komut desteği ve kontrolöre erişim yetkisi ayrıca bilinmelidir. Temel modelde bildirim çıkışıdır.

L2-E2 | Satış verisi alan USB neden önemlidir?

Fiziksel veri sınırıdır. Gerçekten sadece dışa aktarım yapıyorsa programlama senaryosunun dayanağı kalmaz; yine dosya/veri bütünlüğü ve yetkisiz veri erişimi değerlendirilir. R-03 açıkça ek yükleme varsayımına bağlıdır.

L2-E3 | Aynı VLAN yerine farklı VLAN yeterli koruma mıdır?

Hayır. Geçiş yetkileri, kimlik, yönetim erişimi ve fiziksel/işlevsel bağımsızlık gerekir. Z5'e uzaktan programlama yolu açık kaldığında renkli diyagram koruma sağlamaz.

L2-E4 | Ödeme başarısı koruma koşullarını aşabilir mi?

Hayır. Satış talebi yalnız istek üretir; sıcaklık, temizlik ve bakım kilitleri ayrı izin koşullarıdır. Ödeme arızasında satış davranışı tanımlanır; koruma kilitleri kaldırılmaz.

LAB 3 | Threat & Risk Register

Çıktı: Gerekçeli ve sıralanmış Risk Register · **EP 04** · T01/T02 s.4; T03 s.23–33, 43–46

Değerlendirme tarihi 26.10.2026; hazırlayan Batuhan Yaşar Özkan; makine modeli Arminoks Süt Otomatı eğitim modeli v1.0. Gerçek konfigürasyon sürümü bilinmez. Başlangıç, V01–V09 kabulleridir; H hedef kontroller uygulanmış sayılmaz. Mevcut kontrol kanıtı olmadığından puanlar saha bulgusu değil, koşullu eğitim değerlendirmesidir.

Ölçek: L × S × E

Puan	L: kapının istismar edilebilirliği	S: fiziksel sonuç	E: yolun dışarıya açıklığı
1	Zor; özel bilgi/fiziksel erişim veya zincir gerekir	Yaralanma yok; kalite/üretim/ekipman etkisi	Yalnız makine başında fiziksel erişim
2	Orta; zayıf/paylaşılan kimlik bilgisi gerekir	Hafif, geri dönüşlü yaralanma	İşletme ağı veya süreli kontrollü dış erişim
3	Kolay; doğrulama yok/varsayılan, hazır araçla erişim	Ağır/kalıcı yaralanma, ölüm, yangın/patlama	Doğrudan internet veya sürekli açık dış yol

E, insan maruziyeti değildir. Bantlar: 18–27 Kritik; 9–17 Yüksek; 4–8 Orta; 1–3 Düşük. Her S3 ayrı listelenir; en az bir önlem veya yetkili yazılı kabul olmadan kapatılmaz (T03 s.29). Puan yalnız ölçek ve varsayımla anlamlıdır.

Görev: senaryoları kurun ve puanlayın

Föydeki üç senaryo koşulu aşılmış; T03'ün en az üç profil ve beş kapı koşulu, dört profil ve LAB2 G01–G06 envanteriyle karşılanmıştır. Aşağıdaki senaryolar işletilebilir saldırı talimatı değil, savunma amaçlı neden-sonuç modelleridir.

R-01 | Fırsatçı dış: uzaktan koruma mantığının değiştirilmesi

Fırsatçı dış saldırgan, **G01** uzak servis yolundan (V05/V06) bakım istasyonuna ve **G05** normal kontrol programlama yoluna erişir; V08'deki kapak/yeniden başlama mantığını değiştirir. **SF-01/SF-03** bozulur; V02'de bakım yapan kişi erişirken karıştırıcı beklenmedik çalışır ve el/kol ağır yaralanabilir. Bağ: Z0→Z2→Z3→Z4; C01/C02/C03; A02/A03/A07/A08/U03.

L3: Başlangıç varsayımında değiştirilmemiş varsayılan kimlik bilgisi ve sınırsız yazma vardır. S3: Erişilebilir hareketli parçaya yakalanma ağır/kalıcı yaralanmayla sonuçlanabilir. E3: G01 eğitimde sürekli açık dış bağlantıdır. Fiziksel erişimin bakım sırasında gerçekleşmesi ayrıca V02'dir; E puanının tanımı değiştirilmez.

R-02 | Meraklı içeriden: sıcaklık kontrolünün gevşetilmesi

Meraklı içeriden kişi, **G02** yerel paylaşılan servis hesabıyla sıcaklık veya satış engelleme koşulunu değiştirir (V04/V07). **SF-02** etkisizleşir; uzunluğu ve koşulları belirsiz uygunsuz muhafaza sonrasında ürün satılırsa tüketiciye ciddi biyolojik zarar oluşabilir. Bu zincir, gerçek bulaşma veya hastalık bulgusu değildir. Bağ: Z4; A01/A04/U02/F01.

L2: Paylaşılan fakat bilinmesi gereken servis kimlik bilgisi kabul edilir. S3: Koşullu en kötü fiziksel sonuç ciddi hastalıktır; tek sıcaklık sapmasının hastalık yaptığı varsayılmaz. E1: Bu senaryonun giriş yolu yalnız makine başındaki ekrandır. Uzaktan panel erişimi varsa yeni yol ve puan gerekir.

R-03 | Tedarik zinciri: temizlik sırasını bozan servis paketi

Tedarik zinciri saldırganı, **G04** servis paketini değiştirir; paket **G03** USB aktarımıyla yüklenebiliyor kabul edilir (V07/V08). Temizlik ve satışın dışlama/durulama koşulu bozulur, **SF-04** atlanır; V03'teki kimyasal veya sıcak temizleme akışının ürün/erişilebilir dolum yoluna verilmesi ciddi zehirlenme veya yanık doğurabilir. Bağ: Z0→Z3/Z4; C04; A05/A06/W02/W03/F03/F04.

L1: Servis paketini hazırlama/tedarik zincirine yerleştirme ve yerel yükleme zinciri gerekir; USB varlığı tek başına kolay istismar değildir. S3: V03'te kimyasal/sıcak akışın insana ulaşması ciddi fiziksel sonuçtur. E1: Makineye son geçiş fiziksel USB'dir; tedarikçinin internet bağlantısı otomatik E3 yapılmaz.

R-04 | Hedefli: bakım projesi üzerinden yeniden başlama engelinin bozulması

Hedefli saldırgan **G04** bakım aracı/proje dosyasını değiştirir; yerel serviste **G05** üzerinden yüklenen proje SF-03 yeniden başlatma engelini kaldırır (V02/V08). Enerji geri geldiğinde bakım bölgesindeki karıştırıcı çalışabilir; erişen kişi ağır yaralanabilir. Bağ: Z3→Z4; C03; A07/W03/F03/A02/A03.

L1: Hedefe uygun proje bilgisi, dosya değişikliği ve yerel yetkili aktarımın birlikte gerçekleşmesi gerekir. S3: SF-03 bozulduğunda erişilebilir hareket R-01 ile aynı ağır yaralanmayı doğurabilir. E1: Değerlendirilen son erişim yerel bakım bağlantısıdır; R-01'in internet yolu bu senaryoya taşınmaz.

Sıralanmış Risk Register

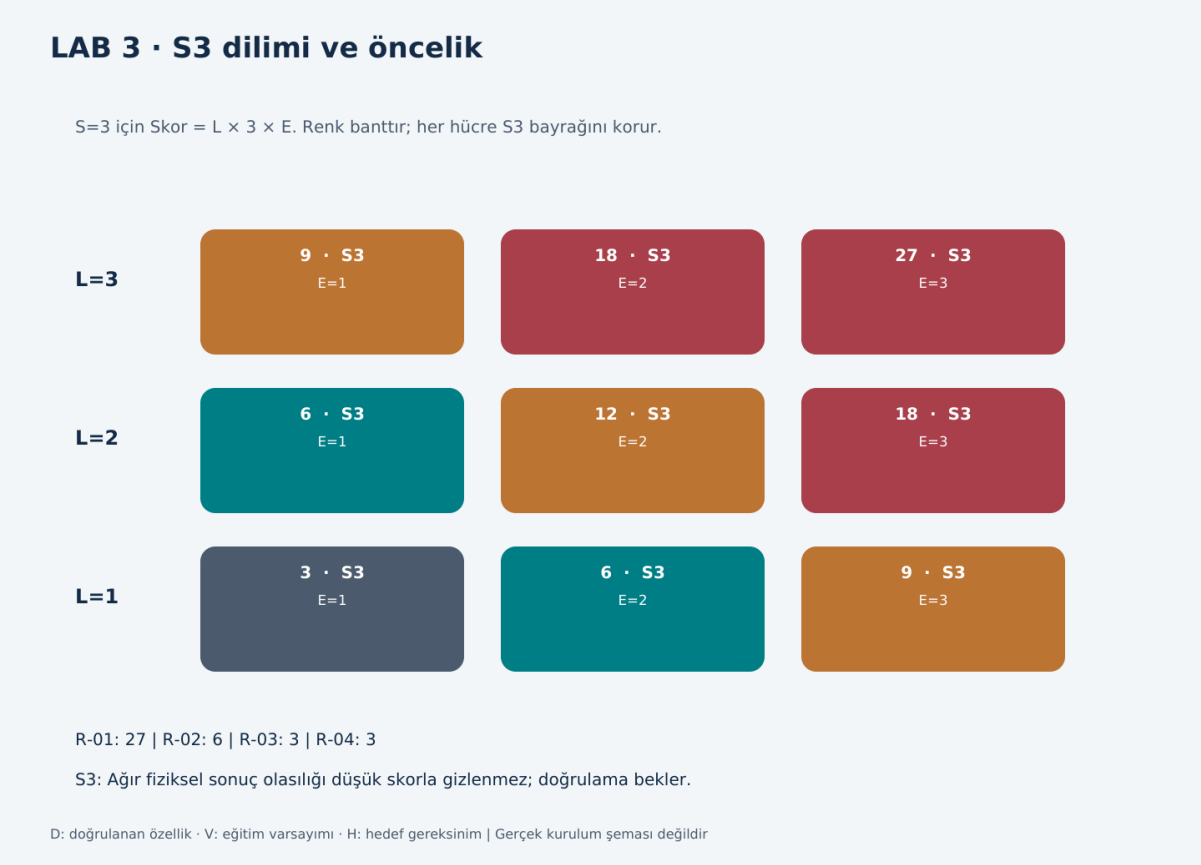
ID	L	S	E	Skor / bant	S3	Öncelik
R-01	3	3	3	27 Kritik	Evet	1
R-02	2	3	1	6 Orta	Evet	2
R-03	1	3	1	3 Düşük	Evet	3
R-04	1	3	1	3 Düşük	Evet	4

R-03/R-04 eşit puanda beraber öncelik grubundadır; tablo sırası idarîdir. İkisi de S3 listesinde açık kalır. Skor dışında veri/üretim kaybı senaryosu örneği, fiziksel zinciri yoksa S1 olarak ayrı yönetilebilir; üç gerekli fiziksel senaryonun yerine geçirilmez.

Yönetim, kanıt ve hedef artık risk

ID	Önerilen işlem	A / R önerisi	Eğitim hedef tarihi	Hedef L/S/E ve koşul
R-01	Kontrolsüz uzak yazmayı kapat; H01/H03, H06/H07	A işletmeci / R OT+servis	25.11.2026	1/3/2=6; erişim kontrolleri doğrulanırsa
R-02	Servis yetkilerini ayır; H02 sıcaklık/satış koruması	A işletmeci / R gıda sorumlusu+OT	24.01.2027	1/3/1=3; yetki denetimi doğrulanırsa
R-03	H04 satış-yıkama dışlaması, H05 güvenilir paket	A işletmeci / R servis+gıda sorumlusu	24.01.2027	1/3/1=3; ölçek tabanı nedeniyle skor değişmeyebilir
R-04	H03 yeniden başlama engeli, H05 proje bütünlüğü	A işletmeci / R servis+emniyet uzmanı	24.01.2027	1/3/1=3; fiziksel doğrulama gereklidir

Roller öneridir; gerçek kişilere görev atanmış değildir. Tarihler dersin 30/90 günlük önerisinden hesaplanmıştır; yakın fiziksel tehlike varsa bu süreler beklenmeden güvenli duruş uygulanır. Mevcut önlemler doğrulanamadı; H kontrollerinin uygulama kanıtı yoktur. Hedef puanlar **gerçek artık risk değildir**. Emniyet bağımsızlığı doğrulansa bile bu kayıtta S3 otomatik S1 yapılmaz; fiziksel zincirin kesildiği kanıt ayrıca kaydedilir. Her risk EP04 kaydına, LAB1 SF'ye, LAB2 kapı/conduit'e ve doğrulama planındaki D01–D05'e bağlıdır.



S3 risk dilimi

Föy soruları

L3-Q1 | En yüksek öncelikli senaryonuz hangisi? Neden?

R-01: Eğitim başlangıcında dışa sürekli açık ve kolay erişilir servis yolu, normal kontrol yazılımındaki koruma koşulunu etkileyerek bakım yapan kişide ağır yaralanmaya uzanabilir.

L3-Q2 | S=3 olup skoru düşük kalan senaryo var mı? Nasıl görünür kılacaksınız?

R-03/R-04 skor 3'tür fakat S3'tür. Ayrı S3 listesi, sorumlu, hedef tarih ve doğrulama kanıtı ile izlenir. R-02'nin orta puanı da S3 yükümlülüğünü kaldırmaz. Bu çalışmada dört kayıt da açık/doğrulama bekliyor.

LAB3 ders notundaki beş tartışma sorusu

L3-T1 | Aynı kapıyı iki farklı profil kullanırsa skor değişir mi?

Profil adı tek başına değiştirmez. Aynı giriş ve kontrol koşulunda L/E tutarlı olmalıdır. Gereken beceri, erişim veya hedef fiziksel işlev değişirse farklı gerekçeyle ayrı kayıt açılır.

L3-T2 | Skoru 27 ama S1 olan senaryo mu, skoru 3 olan S3 mü önce?

Sorudaki ilk sayı aritmetik olarak mümkün değildir: L ve E en fazla 3, S1 ise en yüksek skor 9'dur. Geçerli karşılaştırmada 9/S1 ile 3/S3 arasında fiziksel zarar içeren S3 görünür tutulur; yalnız büyük çarpıma bakılarak bütçe verilmez. Bu, ders notundaki sorunun aynen aktarılmasıyla fark edilen tutarlılık düzeltmesidir.

L3-T3 | Emniyete dokunmayan siber senaryo Register'a girmeli mi?

İşletme etkisi için S1 olarak tutulabilir; emniyet bulgusu diye sunulmaz. Fidye sonrası tehlikeli elle müdahale varsa o ek fiziksel zincir yeni varsayım ve gerekçeyle ayrıca kurulur.

L3-T4 | Tedarikçinin güvenli beyanına ne kadar güvenirsiniz; hangi kanıt gerekir?

Beyan başlangıç bilgisidir. Versiyonlu devre/ağ çizimi, yazma yetkileri, değişiklik kayıtları, cihaz güvenlik belgeleri, paket doğrulaması ve ilgili emniyet test sonuçları gerekir. Bu belgeler bu ödevde firmadan istenmez; bilinmeyenler açık bırakılır.

L3-T5 | Register ne zaman tekrar puanlanmalı?

Yeni zafiyet, firmware/yazılım veya ağ değişikliği, uzaktan erişimin açılması, yeni ödeme/SMS işlevi, arıza/olay, bakımda koruma değişikliği ve varsayımın yanlışlanması durumunda; ayrıca planlı gözden geçirmede.

Ek sorular ve yanıtları

L3-E1 | İnternet bağlantısı hiç yoksa sonuç ne olur?

V05 yanlışlanır; R-01'in bu yolu çıkarılır ve yeni yerel senaryo varsa ayrıca puanlanır. R-02/R-03/R-04 fiziksel erişim ve bakım kabullerine bağlı olarak kalabilir. İnternetsiz cihaz risksiz sayılmaz.

L3-E2 | Temizlik yalnız soğuk suyla yapılıyorsa?

R-03'ün kimyasal/termal sonucu ve S3 gerekçesi geçersizleşir. Gerçek hijyen/bulaşma veya taşma etkisi kendi kanıt ve ölçeğiyle yeniden değerlendirilir; eski puan korunmaz.

L3-E3 | Önlem sonrası skor düşmüyorsa önlem işe yaramaz mı?

Hayır. Üç basamaklı ölçek taban etkisi yaratır; özellikle L1/E1 altına inilmez. Zincirin kesilmesi, test kanıtı ve kalan belirsizlik puandan ayrıca gösterilir.

L3-E4 | En çok tartışılabilecek puan hangisi?

R-02 S3: Gerçek ürün, sıcaklık-süre geçmişi ve tüketici etkisi bilinmez. Koşullu ciddi sonuç açıkça yazılmıştır; olay kanıtı sayılmaz. Bu belirsizlik gıda sorumlusu değerlendirmesiyle azaltılır, uydurma ölçümle kapatılmaz.

LAB 4 | Secure Remote Access

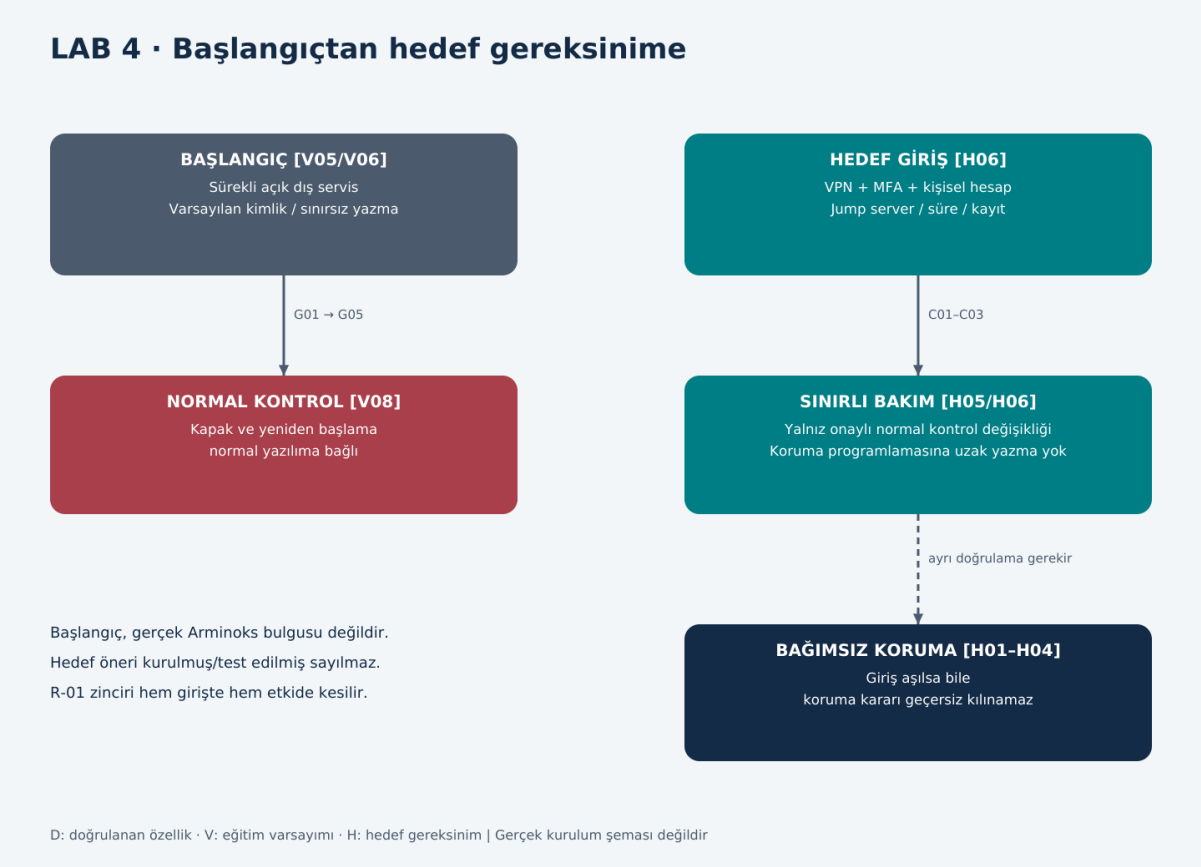
Çıktı: Secure Architecture · **EP 02 / EP 06** · T01/T02 s.5

L4-A | Görev A: Mevcut → hedef

Buradaki mevcut sözcüğü **V05/V06/V08 eğitim başlangıcını** anlatır. Arminoks'ta internete açık servis veya gerçek parola tespit edilmemiştir. K01'in SMS bildirimi uzaktan programlama kanıtı değildir.

Başlangıç modeli

Dış servis sürekli açık G01 yoluyla bakım aracına erişebilir; varsayılan kimlik bilgisi ve kısıtsız G05 yazması kabul edilir. Panel/kontrol yazılımında bulunan kapak, yeniden başlama ve proses izinleri değiştirilebilir. Kişisel hesap, oturum kaydı ve değişiklik onayı kanıtı yoktur. USB'nin program yükleme etkisi ayrıca V07/V08'e bağlıdır. Hedefte bu varsayımların açık bırakılmaması amaçlanır.



Başlangıç ve hedef mimari

Beş tasarım ilkesi ve tünel kontrolü

İlke	Otomata uygulanışı	İz / kabul ölçütü
1. Kontrollü ara nokta	Yalnız Z2 jump server üzerinden bakım	C01/C02 dışındaki yollar reddedilir
2. Kişisel hesap / asgarî yetki	Operatör, servis ve yetkili değişiklik rolleri ayrılır	U02 paylaşımı kaldırılır; her işlem hesapla eşleşir
3. MFA	Uzak girişte ikinci faktör	Yalnız parola ile giriş reddedilir
4. Varsayılan kapalı / süreli	İş emri, yerel onay, bakım penceresi	Süre bitince oturum ve geçiş yetkisi kapanır
5. Oturum / değişiklik kaydı	Oturum, dosya/ayar ve onay kaydı birlikte	Değişen sürüm ve sorumlu izlenebilir

VPN, uzak taşıma yolunu koruyan ek zorunlu kabulümüzdür; asgarî yetki ve emniyet bağımsızlığı yerine geçmez. Bu tablo kurulmuş ürün listesi değil, hedef tasarım gereksinimidir. Gerçek cihaz desteklemiyorsa uygun haricî geçit veya farklı servis yöntemi değerlendirilir.

Görev B: Functional safety köprüsü

L4-B1 | Saldırgan bütün önlemlere rağmen içeri girerse emniyet fonksiyonu etkilenir mi? Neden?

Başlangıç modelinde evet: V08'de normal kontrol yazılımındaki kapak/yeniden başlama koşulları G05 üzerinden değiştirilebilir. Hedefte C01–C03'ün aşılması SF-01/SF-03'ü değiştirmeye yeterli olmamalıdır. Bunun için yalnız ağ ayrımı değil, koruma mantığı/ayarları/çıkışlarının ve yerel değişiklik yolunun bağımsızlığı gerekir. SF-02/SF-04 için de normal satış komutu koruma iznini aşamamalıdır. Hedef gerçekleşmiş veya doğrulanmış sayılmaz.

L4-B2 | Emniyetin kontrol sisteminden ve uzak bakım yolundan bağımsızlığı için gereksinimi yazın.

ID	Üründen bağımsız gereksinim	Nasıl doğrulanır?
H01	Kapak açık veya koruma durumu geçersizken normal kontrolör/uzak komut karıştırıcıda tehlikeli hareket oluşturamamalı; gerekli duruş sağlanmadan erişim olmamalı	D01; en kötü komut ve hata durumunda duruş/erişim ölçümü
H02	Geçersiz sıcaklık veya ürün uygunluğu belirsizken panel/ödeme/uzak komut ürün satışını açamamalı	D02; hata ve geçmiş sapma denemeleri
H03	Enerji, haberleşme veya reset dönüşü kendiliğinden tehlikeli hareket başlatmamalı	D03; ayrı yerel başlatma kontrolü
H04	Satış ile yıkama birbirini dışlamalı; doğrulanmış durulama/temizlik izni olmadan ürün yoluna geçilememeli	D04; durum geçiş ve çıkış testleri
H05	Koruma ayarları ve güvenilir yazılım yalnız yetkili yerel süreçle değişebilmeli; paket kaynağı, bütünlük, önceki sürüm ve onay kaydı korunmalı	D05; yetkisiz/bozuk paket reddi ve sürüm izi
H06	Uzak erişim yerel onaylı süreyle ve kişisel kimlikle sınırlanmalı; koruma programlama yoluna yazma vermemeli	D06; hesap/rota/yetki testleri
H07	Ağ/servis kaybı güvenli davranışı bozmamalı; dolum kilidi ve koruma sürerken güvenli soğutma ihtiyacı ayrıca karşılanmalı	D07; bağlantı kaybı testi

T02'deki ışık perdesi gereksinimi, süt otomatının doğrulanmamış ışık perdesi varmış gibi kopyalanmamıştır; karşılığı H01 ve H03'tür. Gereksinimler bir ürün/PLC markası dayatmaz. H05 bakım değişikliklerini bütünüyle yasaklamak yerine izlenebilir, yerel ve yetkili sürece bağlar.

Süreli bakım prosedürü

1. İşletmeci iş emrini, amacı, kişiyi ve süreyi onaylar; ürün/satış durumu belirlenir.

2. Mevcut proje, ayarlar ve loglar yedeklenir; kullanılan sürüm/hash kaydedilir.

3. Yerel sorumlu C01/C02'yi süreli açar. VPN+MFA ile kişisel hesap kullanılır.

4. Önce salt okunur tanılama yapılır. Gerekiyorsa yazma ayrı onay ve güvenli bakım koşuluyla açılır; Z5 programlama uzak oturuma verilmez.

5. Değişiklik sonrası H01–H07 ile ilgili doğrulamalar ve ürün uygunluğu kontrolleri tamamlanır.

6. Süre sonunda bağlantı/yetki kapatılır; oturum, dosya ve test kayıtları iş emrine bağlanır. Satış/üretim yalnız yerel serbest bırakmayla açılır.

Ek sorular ve yanıtları

L4-E1 | Bakımcı ekranı görebiliyorsa program da yükleyebilir mi?

Görme yetkisi yazma yetkisi değildir. Hedef, ekran/teşhis erişimi ile kontrolör ve koruma konfigürasyonu değişikliklerini ayrı yetkilendirmektir. Gerçek araç ayrımı desteklemiyorsa uzak oturuma genel yönetici yetkisi verilmez.

L4-E2 | Bağlantı kesilince ne olur?

Geçici bakım yetkisi kapanır; koruma yerel çalışmayı sürdürür. Devam eden değişiklik yarım kaldıysa satış ve tehlikeli hareket açılmaz; güvenilir sürüm ve test sonucu olmadan uzaktan yeniden başlatma yapılmaz. Soğutma davranışı H07 kapsamında belirlenir.

L4-E3 | Ayrı Safety PLC varsa tamamen güvende miyiz?

Hayır. Ortak bakım hesabı veya programlama yolu iki sistemi de değiştirebilir. Sensör/çıkış paylaşımı, güç kaynağı, yazılım değiştirme yetkileri ve konfigürasyon bağımsızlığı da değerlendirilir. Bu makinede ayrı Safety PLC varlığı zaten doğrulanmamıştır.

L4-E4 | Öncelikli risk zinciri nerede kırılır?

R-01 için C01'de süreli kimlikli giriş, C03'te sınırlı yazma ve son halkada H01/H03 bağımsız koruma gerekir. İlk katman giriş ihtimalini azaltır; son katman giriş olsa da fiziksel sonucu engellemeyi hedefler. Sonucun kanıtı diyagram değil, D01/D03/D06 testleridir.

LAB 5 | SBOM / CVE / Patch

Çıktı: Vulnerability Decision (VD-01) · **EP 09 / EP 10 / EP 11** · T01/T02 s.6

Girdi ve kararın statüsü

Föyde verilen **Component X, sürüm 2.4, CVE-XXXX-XXXX, CVSS 9.8 ve mevcut yama** bir eğitim girdisidir (V10). CVE-XXXX-XXXX gerçek CVE numarası değildir; bu makinenin bu bileşeni kullandığı bilinmez. CVSS 9.8, insan zararının veya Arminoks'taki gerçek riskin puanı değildir. Temsili bileşen kontrol yazılımında bulunursa H01–H04'e etkisi incelenecek kabul edilmiştir.

VD-01 sonuç: Etkilenme durumu **belirsiz / doğrulama bekliyor**. Gerçek ürüne etkilendi veya etkilenmedi kararı verilmez; yama uygulanmış sayılmaz. Bu belirsizliğe rağmen geçici erişim sınırları ve güvenli işletme kararı tanımlanabilir.

Föy soruları ve yanıtları

L5-Q1 | Bu CVE sizi gerçekten etkiliyor mu? Üç şartı kontrol edin.

Şart	Bu ödevde bilinen	Karar için gereken
Bileşen var mı?	Kontrolör/yazılım bileşen listesi yok	Gerçek BOM/SBOM ve ürün modeli
Sürüm etkileniyor mu?	2.4 yalnız föyün girdisi	Gerçek sürüm + resmî üretici güvenlik duyurusu
Açık ulaşılabilir mi?	Protokol/özellik bilinmez; uzak yol V05	Aktif özellik, yetki, rota ve erişim koşulları

Üçü de kanıtla doğrulanırsa ilgili açıklık için etkilenme kaydı açılır. Bir koşulun karşılanmadığı kanıtlanırsa gerekçeli kapsam dışı/ulaşılamaz kararı verilebilir; ağ değişince tekrar incelenir. Bir koşul bile bilinmiyorsa güvenli değil/etkilenmez diye kesin sonuç verilmez. Bu karar akışı risk değerlendirmesiyle birlikte kullanılır.

L5-Q2 | Üretimi hemen durdurur musunuz? Neden / neden değil?

Sadece temsili CVSS sayısı yüzünden bütün otomatın enerjisi kesilmez. Önce mevcut emniyet ve ürün koşulları değerlendirilir. Koruma bütünlüğü, kontrol mantığı veya ürün uygunluğu güvenilir biçimde doğrulanamıyorsa satış ve ilgili tehlikeli hareket güvenli duruma alınır; güvenli soğutma sürdürülür ve ürün ayrılır. Doğrulanmış etkilenmeme ya da kabul edilmiş telafi kontrolü varsa yetkili işletmeci gerekçeli devam kararı verebilir. Gerçek cihaz değerlendirmesi yapılmadığı için bu çalışma işletmeye devam izni vermez.

L5-Q3 | Yamayı doğrudan mı uygularsınız, önce test mi? Nerede test?

Önce gerçek ürün/sürüm için resmî paket, bütünlük ve bağımlılıklar doğrulanır. Yedek, geri dönüş ve donanım uyumu belirlenir. Hedefle aynı cihaz/firmware/IO düzenini temsil eden izole test düzeneğinde denenir; simülasyon ancak destekleyici kanıttır. Otomatın kendisinde müşteri varken denenmez. Temsilî düzenek yoksa güvenli, planlı bakım ve yetkili devreye alma koşulları oluşturulmadan canlıya yama yüklenmez.

L5-Q4 | Yama safety validation'ı etkiliyor mu? Nasıl anlarsınız?

Sürüm notu ve değişen bileşenin SF-01–SF-04 bağımlılıkları karşılaştırılır. Kapak/duruş, reset, zamanlama, giriş ölçekleme, çıkış varsayılanı ve haberleşme kaybı davranışı etkileniyorsa ilgili emniyet doğrulaması yeniden gerekir. Bileşen kapsamı belirsizse etkisi yok kabul edilmez. D01–D07 testleri, değişiklik etkisine göre uzman tarafından seçilir; gıda güvenliği kontrolleri ayrıca yürütülür. Yalnız normal dolumun çalışması yeterli değildir.

L5-Q5 | Yama mümkün değilse telafi edici önlem ne olur?

Uzak yazma kapatılır, gereksiz servis/özellik devre dışı bırakılır, C03 asgarî izin listesi uygulanır, servis yetkileri daraltılır, USB aktarımı kontrol edilir ve değişiklikler izlenir. Koruma mantığının bütünlüğü doğrulanır; geri yükleme hazırlığı yapılır. Açığın exploit koşulu bilinmeden firewall'ın mutlaka yeterli olduğu söylenmez. Kalan fiziksel risk kabul edilemiyorsa satış/ilgili hareket devre dışı tutulur. Telafi kontrolünün sahibi, süresi ve yeniden inceleme koşulu yazılır.

EP09: Yazılım / SBOM hazırlık taslağı

Bu tablo **gerçek SBOM değildir**. Ürün bileşenleri, sürüm, tedarikçi, tanımlayıcı, bağımlılık ve lisans bilinmeden tamamlanmış SBOM üretilemez. CycloneDX/SPDX biçimine uygunluk veya gerçek VEX kaydı iddia edilmez.

Kimlik	Bileşen / kapsam	Sürüm / tedarikçi	Kanıt durumu
SW-01	Panel uygulaması W01	Bilinmiyor	V01; envanter doğrulaması gerekli
SW-02	Kontrolör firmware / mantık W02	Bilinmiyor	V01/V08
SW-03	Bakım aracı W03	Bilinmiyor	V05/V08
SW-04	Ağ geçidi yazılımı A08	Bilinmiyor	V05; gerçek kurulumda olmayabilir
SW-X	Föyün Component X kütüphanesi	2.4; tedarikçi belirtilmemiş	V10; yalnız eğitim girdisi

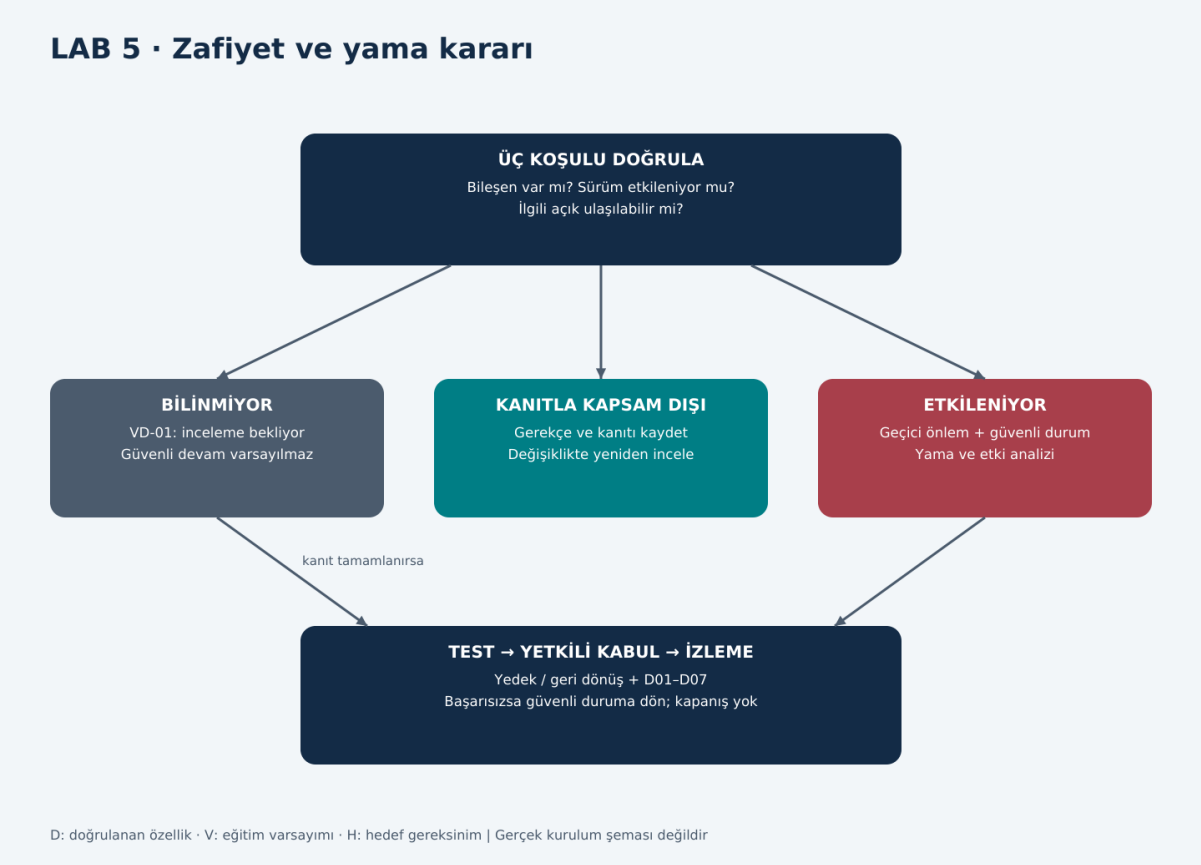
Gerçek kayıtta ayrıca hash, ürün/seri numarası, bağımlılık, kaynak, edinim tarihi, etkilenen özellik ve duyuru bağlantısı bulunmalıdır. Bu alanlara rastgele değer yazılmaz.

EP10: Zafiyet karar kaydı

Alan	VD-01
Makine / analiz sürümü	Arminoks süt otomatı eğitim modeli v1.0
Kayıt tarihi / hazırlayan	26.10.2026 / Batuhan Yaşar Özkan
Girdi	Component X 2.4; temsili CVE; CVSS 9.8; yama mevcut (V10)
Etkilenme	Belirsiz: bileşen, sürüm, ulaşılabilirlik doğrulanmadı
İlgili riskler	Etki eşleştirmesine göre R-01–R-04; otomatik olarak hepsi etkilenmiş sayılmaz
Geçici karar	Kontrolsüz erişimi sınırla; bütünlük/ürün güveni yoksa güvenli duruma al
A / R önerisi	İşletmeci / OT-servis; ürün etkisinde gıda sorumlusu
Açık ihtiyaç	Gerçek ürün/SBOM, duyuru, desteklenen yama, test ve geri dönüş kanıtı
Statü	Taslak; inceleme bekliyor; kapatılmadı

EP11: Yama ve geri dönüş kayıt taslağı

Aşama	Kaydedilecek kanıt	Bu çalışmadaki durum
Öncesi	Cihaz/sürüm, yedek hash'i, ayarlar, onay	Gerçek cihaz bilgisi yok
Paket	Resmî kaynak, imza/hash, sürüm notu, bağımlılık	Temsili yama; paket indirilmedi
Test	Düzenek tanımı, D01–D07 sonuçları, ürün kontrolü	Planlandı; uygulanmadı
Devreye alma	İş emri, saat, sorumlu, yeni sürüm	Yapılmadı
Geri dönüş	Eski sürüme destekli dönüş, veri/ayar uyumu, tekrar test	Yeteneği bilinmiyor; otomatik vaat edilmez
Kapanış	Onaylı test, izleme ve Register güncellemesi	Açık



Yama karar akışı

Ek sorular ve yanıtları

L5-E1 | Gerçek CVE bulmadan LAB5 tamamlanabilir mi?

Evet. Föy açıkça temsili kayıt veriyor; beklenen çıktı bu kayıt üzerinden gerekçeli karar akışıdır. Ödevi güçlendirmek adına ilgisiz gerçek CVE'yi cihaza yakıştırmak doğruluğu azaltır.

L5-E2 | Hash doğruysa paket güvenilir midir?

Hash yalnız karşılaştırılan referans güvenilir ise bütünlük kanıtına katkı verir. Saldırganın paketle birlikte verdiği hash kaynak doğrulaması değildir. Üreticinin resmî dağıtımı, imza/güven kökü ve doğru ürün-sürüm uyumu ayrı kontrol edilir.

L5-E3 | Geri dönüş desteklenmiyorsa ne yaparız?

Deneme yanılma ile canlıya geçilmez. Uyumlu yedek cihaz, destekli kurtarma veya başka planlı güvenli servis yöntemi gerekir. Böyle bir yol yoksa telafi kontrolleri ve risk kabulü yeniden değerlendirilir; güvenli devam kanıtlanamıyorsa işletme açılmaz.

L5-E4 | Kapanış için hangi somut sonuç gerekir?

Gerçek etkilenen varlık tanımlanmış, yama veya telafi kontrolü doğrulanmış, ilgili SF testleri ve ürün uygunluğu onaylanmış, sürüm/log/yedek kayıtları tutulmuş ve risk sahibi kararı kaydetmiş olmalıdır. Dosyanın hazırlanması veya paketin yüklenmesi tek başına kapanış değildir.

Destek | SWOT, doğrulama ve sunum özeti

Bu bölüm ek değerlendirmedir; föy sorularının yerine geçmez. Saha hakkında olumlu/olumsuz güvenlik hükmü vermez.

SWOT: eğitim modelinin değerlendirmesi

Boyut	Değerlendirme	Dayanak
Güçlü	Üretici sıcaklık, otomatik yıkama, panel ve USB özelliklerini yayımlamış	D02/D05/D07; analiz için açık başlangıç
Zayıf / bilgi eksikliği	Sürüm, devre, ağ, erişim ve koruma donanımı bilinmiyor	Gerçek kurulum hakkında sonuç sınırı
Fırsat	Satış izni, ürün uygunluğu ve bakım koruması ayrı gereksinimlere bağlanabilir	H01–H07; izlenebilir tasarım
Tehdit / koşullu	Bakım yazması veya program değişikliği koruma koşullarını aşabilir	V05–V08; R-01–R-04

Doğrulama planı: gerçek test yapılmadı

Testler yalnız yetkili ve güvenli test düzeneğinde yapılmalıdır. Gerçek makinede müşteri varken koruma bypass edilmez. Yazılım dosyası kontrolleri bu testlerin yerine geçmez.

Test	Gereksinim	Deneme	Tamamlanma ölçütü
D01	H01 / SF-01	Kapak açık, hata bilgisi ve hareket talebi kombinasyonları	Tehlikeli hareket yok; duruş/erişim süresi uzman ölçümüyle uygun
D02	H02 / SF-02	Ölçüm kaybı, geçersiz değer, geçmiş uygunsuzluk, sahte normal ekran	Satış kapalı; güvenli soğutma/uyarı sürer; ürün onayı gerekir
D03	H03 / SF-03	Enerji dönüşü, reset, haberleşme geri gelişi	Kendiliğinden hareket yok; ayrı yerel başlatma
D04	H04 / SF-04	Satış ve yıkama talebinin aynı anda verilmesi; durulama belirsizliği	Ürün ve tehlikeli temizleme yolları birlikte açılmaz
D05	H05	Yanlış ürün paketi, bozuk bütünlük, yetkisiz ayar/proje değişikliği	Reddetme, kayıt, güvenilir yedek ve destekli kurtarma kanıtı
D06	H06	Yanlış rol, MFA eksikliği, süre bitimi, koruma programlama isteği	Giriş/yazma reddi; süre sonunda erişim kesilir
D07	H07	Ağ/panel/servis bağlantısı kaybı	Koruma çalışır; satış izni kendiliğinden gelmez; soğutma güvenli davranır

İş planı ve tamamlanma ayrımı

1. Kaynak ve kapsam: LAB1–5 ve üretici özellikleri eşleştirildi.

2. Analiz: İşlev, giriş, risk ve gereksinimler birbirine bağlandı.

3. Teslim: Markdown, diyagramlar, PDF ve kontrol verileri üretildi.

4. Gerçek uygulama: Donanım incelemesi, güvenlik tasarımı, kurulum ve D01–D07 testleri **yapılmadı; eğitim tesliminin dışındadır**.

Nihai eğitim hedefi, eksiksiz ve dürüstçe sınırlandırılmış analizdir. Gerçek makinenin güvenli olduğunun kanıtlanması farklı bir hedef ve yetkili saha çalışması gerektirir.

Terslikler ve önlemler

Terslik	Önlem / B planı
Ürün broşüründeki farklı makineyi karıştırmak	K01 s.4–6 otomat bölümünü kullan; s.3 tank kapağı işlevini otomata taşıma
SMS'i internet/uzaktan komut sanmak	D06 ile V05'i ayrı tut
Bilinmeyen sürümden gerçek CVE sonucu çıkarmak	VD-01 belirsiz; gerçek SBOM/duyuru olmadan kesin karar yok
Güvenli duruşta soğutmayı gereksiz kesmek	İşlev bazlı güvenli durum; bakım izolasyonu ayrı
Küçük risk skorunda ağır yaralanmayı unutmak	S3 listesi, sorumlu ve kapanış kanıtı
PDF ve Markdown'ın ayrışması	Aynı Markdown'dan tekrar üretim ve dosya kontrolleri

Kısa sunum metni

Arminoks süt otomatını kamuya açık üretici bilgileriyle inceledim. Önce doğrulanan özellikleri varsayımlardan ayırdım. Ardından bakım hareketi, sıcaklık ve temizlik izinlerini koruma işlevlerine bağladım. Ağ modelinde altı giriş kapısı belirledim; dört farklı profil için fiziksel sonuçla biten risk senaryoları yazdım. E puanını insan maruziyeti olarak değil, yolun dışarıya açıklığı olarak kullandım. Uzak erişimde kimlik, süre ve kayıt kontrollerinin yanında koruma bağımsızlığını tanımladım. LAB5'te gerçek bileşen bilgisi bulunmadığı için temsili CVE üzerinden belirsizliği koruyan yama kararı hazırladım. Bu sonuç gerçek makinede açık bulduğum veya emniyet testi yaptığım anlamına gelmiyor.

Teslim kontrolü | Föy ve yanıt eşleştirmesi

Kapsam: LAB 1–5. Genel föy ana görev kaynağı, PaketPro uyarlama örneği, LAB3 ders notu ölçek ve tartışma kaynağıdır. LAB6–7 dahil değildir.

Ana görevler, kararlar ve ders tartışmaları

Kimlik	Karşılanan görev	Yanıt
L1-Q1	Bu makinede tehlike nedir? İnsan neyden zarar görür?	LAB 1
L1-Q2	Safety function (emniyet fonksiyonu) hangisidir?	LAB 1
L1-Q3	Safety-related control system nerede? Şemada işaretleyin.	LAB 1
L1-Q4	Normal PLC ile Safety PLC farkı nedir?	LAB 1
L1-Q5	PLr / SIL neden var? Bu fonksiyon için neden önemli?	LAB 1
L1-Q6	Safe state (güvenli durum) nedir?	LAB 1
L1-Q7	Safety function hangi dijital bağımlılıklara sahip?	LAB 1
L1-Q8	Siber müdahale hangi noktadan bu fonksiyonu bozar?	LAB 1
L2-A1	Hangi varlıklar aynı bölgede? Bölgeleri adlandırıp gruplandırın.	LAB 2
L2-A2	Safety PLC'yi hangi bölgeye koydunuz, neden?	LAB 2
L2-A3	Conduit'ler nerede? Her geçişte ne kontrol edilecek?	LAB 2
L2-B1	Aracı: seçim ve gerekçe	LAB 2

Kimlik	Karşılanan görev	Yanıt
L2-B2	Tünel: seçim ve gerekçe	LAB 2
L2-B3	Kimlik: seçim ve gerekçe	LAB 2
L2-B4	Hesap: seçim ve gerekçe	LAB 2
L2-B5	Kayıt: seçim ve gerekçe	LAB 2
L2-B6	Zamanlama: seçim ve gerekçe	LAB 2
L2-P1	PaketPro varyantı: Açık uzak bakım modülü hangi bölgeye düşüyor; orada kalabilir mi?	LAB 2
L3-Q1	En yüksek öncelikli senaryonuz hangisi? Neden?	LAB 3
L3-Q2	S=3 olup skoru düşük kalan senaryo var mı? Nasıl görünür kılacaksınız?	LAB 3

Kimlik	Karşılanan görev	Yanıt
L3-T1	Aynı kapıyı iki farklı profil kullanırsa skor değişir mi?	LAB 3
L3-T2	Skoru 27 ama S1 olan senaryo mu, skoru 3 olan S3 mü önce?	LAB 3
L3-T3	Emniyete dokunmayan siber senaryo Register'a girmeli mi?	LAB 3
L3-T4	Tedarikçinin güvenli beyanına ne kadar güvenirsiniz; hangi kanıt gerekir?	LAB 3

Kimlik	Karşılanan görev	Yanıt
L3-T5	Register ne zaman tekrar puanlanmalı?	LAB 3
L4-A	Görev A: Başlangıç ve hedef mimari; beş ilke	LAB 4
L4-B1	Saldırgan bütün önlemlere rağmen içeri girerse emniyet fonksiyonu etkilenir mi? Neden?	LAB 4
L4-B2	Emniyetin kontrol sisteminden ve uzak bakım yolundan bağımsızlığı için gereksinimi yazın.	LAB 4
L5-Q1	Bu CVE sizi gerçekten etkiliyor mu? Üç şartı kontrol edin.	LAB 5
L5-Q2	Üretimi hemen durdurur musunuz? Neden / neden değil?	LAB 5
L5-Q3	Yamayı doğrudan mı uygularsınız, önce test mi? Nerede test?	LAB 5
L5-Q4	Yama safety validation'ı etkiliyor mu? Nasıl anlarsınız?	LAB 5
L5-Q5	Yama mümkün değilse telafi edici önlem ne olur?	LAB 5

Makineye özgü ek sorular

Beş laboratuvarda dörder, toplam **20 ek soru** yanıtlandı. Eksik saha verileri gerçekmiş gibi tamamlanmadı.

Kimlik	Ek soru	Yanıt
L1-E1	Her şeyi kapatmak neden her zaman güvenli değildir?	LAB 1
L1-E2	Panel normal sıcaklık gösteriyorsa satış yapılabilir mi?	LAB 1
L1-E3	Reset neden başlatma olmamalı?	LAB 1
L1-E4	Emniyet bağımsızlığını nasıl sınarız?	LAB 1
L2-E1	SMS modülü internet saldırı yolu mudur?	LAB 2
L2-E2	Satış verisi alan USB neden önemlidir?	LAB 2
L2-E3	Aynı VLAN yerine farklı VLAN yeterli koruma mıdır?	LAB 2
L2-E4	Ödeme başarısı koruma koşullarını aşabilir mi?	LAB 2

Kimlik	Ek soru	Yanıt
L3-E1	İnternet bağlantısı hiç yoksa sonuç ne olur?	LAB 3
L3-E2	Temizlik yalnız soğuk suyla yapılıyorsa?	LAB 3
L3-E3	Önlem sonrası skor düşmüyorsa önlem işe yaramaz mı?	LAB 3
L3-E4	En çok tartışılabilecek puan hangisi?	LAB 3

Kimlik	Ek soru	Yanıt
L4-E1	Bakımcı ekranı görebiliyorsa program da yükleyebilir mi?	LAB 4
L4-E2	Bağlantı kesilince ne olur?	LAB 4
L4-E3	Ayrı Safety PLC varsa tamamen güvende miyiz?	LAB 4
L4-E4	Öncelikli risk zinciri nerede kırılır?	LAB 4
L5-E1	Gerçek CVE bulmadan LAB5 tamamlanabilir mi?	LAB 5
L5-E2	Hash doğruysa paket güvenilir midir?	LAB 5
L5-E3	Geri dönüş desteklenmiyorsa ne yaparız?	LAB 5
L5-E4	Kapanış için hangi somut sonuç gerekir?	LAB 5

Teslim kalitesi ve kapsam sınırı

Kontrol	Tamamlanma ölçütü
Kimlik ve kapsam	Ad, öğrenci numarası, atanan makine; LAB1–5
Bilgi ayrımı	D/V/H tanımları; gerçek ve eğitim modeli ayrımı
LAB1	8 ana soru, SF tablosu, normal/koruma diyagramı
LAB2	Altı kategori, 6 kapı, zone/conduit, 6 erişim kararı
LAB3	4 senaryo/4 profil; L/S/E gerekçeleri; S3, sahip, tarih, hedef risk
LAB4	Başlangıç/hedef ve 7 test edilebilir gereksinim
LAB5	Üç koşullu etkilenme; temsili CVE; belirsiz karar; SBOM/yama kayıt taslakları
İlave kapsam	20 ek soru; 5 ders tartışması; SWOT ve doğrulama planı
Çıktı	8 bölüm PDF + 1 birleşik PDF; Markdown; risk JSON/CSV; üretim/kontrol araçları
Sınır	Gerçek cihaz testi, yama kurulumu, gerçek SBOM ve sertifikasyon yok